

External attack surface management (EASM) buyer's guide

A guide to choosing the right EASM product for your organisation, and the security features you need to consider.

External attack surface management (EASM) is the process of identifying, monitoring, and reducing vulnerabilities within assets that are accessible from the internet. This guidance will help system owners to choose an EASM product that is appropriate for their organisation. Vendors may also find this guidance useful when designing and developing EASM solutions.

What is EASM?

Attackers constantly scan organisations' IT systems (the hardware, software, services and cloud assets), looking for weaknesses they can use to gain access, or to steal data. The sum of potential access points is known as the 'attack surface', and attack surface management (ASM) is the process of identifying, monitoring, and reducing vulnerabilities across the entirety of an organisation's digital and physical assets.

External attack surface management (EASM) is a subset of ASM, and focuses on protecting online assets that are accessible from the internet. EASM products provide automated discovery of your external attack surface, and help you to understand the risks and, where necessary, what actions to take. EASM products offer a lower barrier of entry into ASM for most consumers, compared to the cost and expertise of 'in-house' vulnerability scanning.

Since EASM products scan your online presence from an external viewpoint, they present network defenders with a view of the attack surface as seen from an attacker's perspective. This includes attackers that may be targeting you specifically, as well as those scanning the whole internet for vulnerabilities to compromise indiscriminately. EASM products contribute to maintaining the 'defender's edge' by ensuring you have the same – or better – visibility of your online systems as potential attackers.

EASM products can be an effective way to quickly build an understanding of your overall external attack surface, and continuously monitor it for new risks. EASM products should be considered by organisations with responsibility for maintaining multiple internet-accessible services as part of their vulnerability management regime, especially where disruption to those services would impact business or customers.

Internal and external ASM

Some tools in the EASM category offer combined external and internal monitoring, sometimes under the name 'cyber asset attack surface management' (CAASM) or just ASM. Providing a holistic view of internal and external attack surface likely requires deployment of a software agent into networks, or integration with cloud suppliers. This can include integration with your existing endpoint detection and response (EDR) capabilities to enrich the data collected from an external perspective.

Note: This guidance focuses on EASM products that do not require additional deployment or integration, although many will offer these options. If your requirement is to focus on internal risks, you should refer to the NCSC's [separate guidance on vulnerability scanning tools and services](#).

How do EASM products work?

EASM products work by making connections to the domains and IP addresses provided (or discovered by the product). These connections are typically lightweight, sending and receiving the minimum amount of data required to identify technologies and services. This can include attempting to connect to assets on multiple different ports (sometimes known

as port scanning) to identify all the different services running on a server. It can also include emulating the activity of how a typical user would interact with your online services, such as by browsing web pages.

Some EASM products are standalone products, whereas others integrate EASM features into existing platforms. Whilst the specific features of EASM products will vary (as discussed below), all of them perform the following functions:

In almost all cases, using an EASM product does not increase the risk to your online services. If your services are exposed to the internet, they are already being scanned daily by various internet-wide scanning services, researchers, and potentially malicious actors across the world. Any scanning and analysis conducted from an external viewpoint by an EASM product could equally be conducted by an attacker. Adopting an EASM product ensures you know which of your services can be seen and attacked externally, allowing you to prioritise your defences.

Benefits of using EASM products

Whilst it is possible to manually monitor your external attack surface, an EASM product brings together a range of features into an automated service, handles the practical challenges of maintaining a constantly updated view, and often provides an easy-to-use interface. If you are not already maintaining a thorough register of your assets (including software versions, lifecycle tracking, and risk assessment), EASM products can help you get started quickly.

An EASM product will support you in your [vulnerability management](#) process, particularly in [identifying your assets](#), and discovering vulnerabilities quickly. EASM products can identify a broader range of weaknesses in your attack surface than specific software vulnerabilities that require patching, for example those listed in [MITRE's Common Vulnerability Enumeration \[CVE\] database](#). This could include exposed services that shouldn't be accessible via the internet, DNS misconfigurations, and email security weaknesses. All these issues, including software vulnerabilities, are vulnerable points in your attack surface. For this reason, EASM products often refer to findings as 'issues' or 'risks' rather than vulnerabilities, although this can include software vulnerabilities too.

EASM products offer ongoing continuous monitoring and automated asset discovery, often refreshing daily. This regular monitoring regime provides you with up-to-date information, and is key to successful vulnerability management by reducing the time between exposure and discovery, and ultimately mitigation of a vulnerability.

Finally, EASM products provide visibility of the entire attack surface, and this allows you to identify anomalies specific to your organisation. This may include old configuration pointing at legacy suppliers, services that should have been decommissioned, or exposed services that should be internal only. In this way, EASM products can support meeting and monitoring compliance with your business and security policies. **To get the most out of EASM, you should aim to combine the technical insights that the product provides with your unique insight into how your business operates.**

Features of EASM products

The user experience and features included across EASM products vary considerably, as developers have tailored their solutions to address different customers working with different technologies across various sectors. Having said this, EASM features can be categorised into the following three groups.

Visibility and insight

Features which provide attack surface visibility, which users can directly access or interrogate to identify anomalies.

See visibility and insight examples

+

Show

- Asset discovery:** automatic discovery and visibility of online assets, primarily domain names (including subdomains) and IP addresses owned by or associated with your organisation.

- **Technology identification:** visibility of the technology used by your organisation and where possible the specific models or versions, such as web server software, firewalls or SaaS products.
- **Service identification:** visibility of exposed services such as SSH, FTP, databases, or web servers.
- **DNS configuration:** visibility of the DNS records and configuration across all domain assets.
- **Web presence:** a deeper look at any exposed websites, including parsing web pages, identifying technologies, or taking screenshots.
- **Certificates:** visibility of the TLS certificates in use by your organisation, including suppliers, expiry monitoring, and additional analysis.
- **Supplier identification:** visibility of the technology suppliers on which your organisation relies, including software vendors, cloud services, ISPs, mail providers.

Security analysis

Features to assist with the analysis of the attack surface, identifying risks or issues for action (often with remediation advice and explanatory references).

See security risks examples

+ Show

- **Software security:** identifying unpatched or unsupported out of date software, specific vulnerable misconfigurations, or other known issues.
- **Email security:** checking [anti-spoofing controls](#) such as SPF, DMARC, and MTA-STS.
- **Web security:** checking web server configuration, use of secure HTTP headers, external dependencies.
- **DNS security:** identifying domains vulnerable to takeover, such as dangling CNAMEs, or other weak DNS configurations.
- **Exposed services:** identifying services exposed to the internet that shouldn't be, such as databases, or services lacking required authentication or other weak configurations.
- **Vulnerability assessment:** checking if systems are vulnerable to specific vulnerabilities, often by testing with benign variants of known exploits.
- **Threat intelligence:** identifying relevant threat intelligence or breach evidence relating to known assets.

Supporting functions

Additional features to support further exploration of the attack surface, understanding the risks, and prioritising actions.

See supporting functions examples

+ Show

- **Workflow features:** features to improve the workflow, such as adding comments to issues, tagging colleagues, setting status fields or grouping issues into actions.
- **Dashboards and views:** providing multiple ways to view the collected attack surface information, allowing users to explore the data and identify anomalies.
- **History and trends:** the tracking of risks and metrics over time or ability to look back at attack surface state on a given date to easily make comparisons and track improvement.
- **Summarised reporting features:** producing downloadable reports giving an overview of the attack surface, including size, technologies in use, highest risks, and trend analysis.
- **Raw data exports:** exports of lists of security issues, for example in CSV format.
- **3rd party integrations (output):** integrations including dataflows into SIEM tools, or the ability to automatically create tickets in external workflow tools.
- **3rd party integrations (input):** integrations to provide data into the EASM tool, such as to automatically load information from asset databases, cloud inventories, or other suppliers. This can enrich the data in the tool, and significantly improve the coverage achieved by asset discovery.

- **Configurable prioritisation:** the ability to adjust the severity or priority rating assigned to particular issues based on your own organisation’s risk tolerances.
- **Hierarchical organisational access control:** setting up a parent/child relationship where an organisation can view data across several other organisations but they can’t see each other’s data (useful for subsidiaries or those providing security services to multiple customers).

How to choose an EASM product

Choosing the EASM that is right for your organisation will depend on many factors including:

- the size and nature of your organisation
- your existing record keeping and understanding of your online assets
- your current level of monitoring or vulnerability scanning
- the current security challenges you are facing

There is no ‘one size fits all’. Choosing an EASM product is about identifying which product will best address your organisation’s specific needs. You should also note that the ‘best’ EASM for you may change over time as your organisation evolves.

This section provides a set of questions to ask yourself (and any prospective EASM providers you are engaging with) to help you select the most appropriate product.

+ Show All

1. What are you trying to achieve?

+ Show

Think about the security challenges you currently face, and how external monitoring could support you. Consider the different EASM functions and features outlined above. You may have any number of priorities, which could include:

- seeing your entire attack surface mapped out
- building an accurate record of your digital assets
- specific monitoring to meet compliance requirements
- ensuring email anti-spoofing controls are deployed
- prioritising support where you know you have multiple risks

The more specific your objectives for using an EASM product, the more likely you are to select one that’s right for you. Although every organisation is unique, below we’ve listed some scenarios that illustrate typical requirements.

Example A: Small business

Organisation A is a small business with no in-house technical support. They have their own domain and run some websites, email, and online services developed some time ago by a third party.

Organisation A wants to focus on ensuring their online assets are not vulnerable, perhaps due to a lack of maintenance that has failed to keep software up to date. They want an EASM product that provides clear understandable advice on the risks and actionable information about what they need to do.

Example B: SME

Organisation B has a number of subdomains created over many years to host various web services, many of which no longer exist. The organisation knows that not all subdomains will have been correctly decommissioned, possibly leaving some vulnerable to takeover by cyber criminals.

Organisation B wants to focus on identifying and removing these old subdomains. They want an EASM product that performs well at discovering subdomains, and detecting lots of different scenarios in which domains are vulnerable to takeover.

Example C: Large enterprise

Organisation C has a large IP address space hosting many different services across the business. They are aware that old and vulnerable software and services exist across their estate, that the security team are not aware of.

Organisation C wants to focus on identifying deprecated vulnerable services across a large number of IP addresses. They want an EASM product that can support large IP ranges, excels at service identification, and provides exports of risks to share with other teams.

2. How is the attack surface discovered?

+ Show

An essential feature of EASM products is ongoing automated discovery of your attack surface. Discovery will typically blend many sources of technical and non-technical data, including public information such as DNS and certification information.

EASM products may offer additional API connectors to integrate with suppliers (such as cloud providers) to provide better coverage of your assets. You should consider which integrations, if any, you require to get the most value from your monitoring.

Effective automated discovery will validate or 'confidence score' discoveries before presenting, and allow you to exclude any out-of-scope discoveries.

3. Who will access the tool or need to see the information?

+ Show

Consider who needs access to the information from the EASM product. Different users may need access to different information. Consider who needs to know about misconfigurations or vulnerabilities, and what actions will be taken. If you will be sending information to third party IT suppliers or security companies, consider what export features you might need.

Similarly, consider who needs to know information about the discovered attack surface, including IP addresses, domain names (including subdomains), certificates, websites, services, and any other externally discovered items. Different tools will have different ways of displaying this information. You should consider if you intend to export the data into existing tools, or would benefit from additional features within the EASM tool to view and analyse the data in place.

Most EASM products have export features, which can provide different types of files, for sharing with people who don't have direct access to the EASM tool. If you are expecting to send information externally, ask to see example output from the providers you are considering. This can include:

- detailed information about a single issue (often exported as PDF files) which is useful for sending to colleagues or third parties so they can take remedial action to resolve the issue
- overviews designed for board-level understanding, often with charts and metrics
- full lists of issues (including types, severities and instances), often exported as CSV files which can be opened in Excel and other common tools

4. How will you interact with the tool?

+ Show

Most EASM products provide an interface accessible from a web browser. Some can provide integrations into your existing workflow or ticketing system. Think about how you want to use the EASM tool. Do you want it to push information to you, for example through email alerts? Or do you only want to log in and view the information when you choose?

Many of the additional EASM platform features can only be accessed if you log into the web interface. For less experienced users, this way of using the products is recommended. For organisations with established security monitoring, consider if a feed from the EASM product into your existing SIEM tool would be helpful, and check compatibility with the EASM providers.

You have the best understanding of your own business policies and context. Ask any prospective EASM supplier(s) what tools and features are provided for you to navigate the EASM data. Consider how you could identify issues or

anomalies that might not automatically be raised as risks, but that are not acceptable for your business.

5. How will you prioritise identified risks?

+ Show

EASM products often identify a large number of issues with a wide range of severity. Consider how you will prioritise these risks and decide which actions to take first. You may wish to prioritise based on:

- where in the attack surface the issue is
- the likelihood of it being exploited
- the impact that could occur

Your EASM product should help you to focus on what matters most to your organisation, and to prioritise your actions. This can include:

- providing clear provenance of any discovered attack surface and all findings
- incorporating threat intelligence, or annotating CVE vulnerabilities using the [Known Exploited Vulnerabilities \[KEV\] Catalog from CISA](#)
- providing accurate findings, and clearly marking any that have low confidence
- allowing removal of false positives
- the ability to accept or ignore specific risk instances or risk types
- workflow features or external workflow integrations
- integrations with suppliers such as cloud providers, certificate authorities or DNS providers to help quickly identify where action is needed

6. How current does the data need to be?

+ Show

A primary benefit of EASM products is the continuous nature of the monitoring. How up to date this is depends on the frequency of the underlying scanning data and subsequent analysis. The more current the data is, the less time it takes to:

- identify and resolve risks
- reduce the time that your organisation is exposed
- validate that your actions have resolved the issues

Consider how important the timeliness of the data is to you. This might include updating hourly, daily or weekly. Note that the update frequency may not be the same for all types of checks within the tool, so be sure to ask prospective EASM providers about your specific requirements. Some products also offer on-demand scans to check immediately if you have resolved an issue.

Note: Understanding the weaknesses in an attack surface requires up-to-date knowledge of different software and services used by organisations, awareness of current vulnerability types, and understanding of techniques used by attackers. It's vital that your chosen EASM vendor keeps up to date with new attack types and risks, rapidly responds to new priority threats, and continuously updates their detection capabilities and platform features.

7. Do you also need vulnerability assessment?

+ Show

EASM products can warn you if your systems are **likely** to be impacted by known vulnerabilities with assigned CVE numbers. This is often achieved by determining the version of the technologies you are using, and cross-checking this against the versions which are known to be vulnerable. These warnings will tell you if your software is out of date and needs patching.

Vulnerability assessment or vulnerability scanning is the practice of checking if live systems are **definitely** vulnerable to specific vulnerabilities, using carefully crafted non-malicious payloads to validate.

Some EASM products can integrate with vulnerability scanning tools, or offer vulnerability assessment as an additional feature. This often requires additional configuration and permissions, due to increasing the potential impact of the

scans, and legal requirements.

Consider if you require vulnerability assessment as part of your EASM offer. Before enabling features like this, you should understand how your organisation would respond to scans that might trigger other security software (such as an intrusion detection system). Ask any potential EASM provider(s) how you will be able to rapidly identify their traffic so your security teams don't waste time investigating scans as potential attacks.

Note: If you chose not to use vulnerability scanning from an EASM product, you may still receive traffic of this type from scanners and indiscriminate attackers all across the internet.

Well-designed EASM products are responsible with their scans. They limit the impact on scanned services, both in terms of bandwidth and intrusion, and allow users to adjust tolerances. For vulnerability scanning in particular, traffic should be easily identifiable as originating from the EASM product, including by providing source IPs and marking traffic wherever practical (for example in HTTP User Agents).

PUBLISHED

18 September 2025

REVIEWED

18 September 2025

VERSION

1.0

WRITTEN FOR

Large organisations Public sector Self employed & sole traders Small & medium sized organisations